

Security+ 1.2 · Deception & Disruption

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 1.2 — Deception & Disruption (4:30) · [Vídeo no YouTube ↗](#)

Resumo da Aula: Isca e engana: honeypot (máquina falso), honeynet (rede de honeypots), honeyfiles (arquivo-isca), DNS sinkhole (redireciona domínio malicioso pra nada), false azure (serviço que finge ser cloud). Detecta e estuda o atacante.

Highlights que a prova cobra

- Honeypot = alvo falso: parece real, é monitorado
- Honeyfile: documento-isca com beacon — dispara alerta ao abrir
- DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou

Dicas de prova & Cenários Típicos

- 'appears vulnerable but is monitored' = honeypot
- 'redirects malicious domain traffic' = sinkhole

Cenário clássico de exame: Cenário típico: 'empresa coloca servidor falsamente vulnerável pra detectar e estudar intrusão' → honeypot.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 1.2)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Deception & Disruption) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Criptografia Simétrica (AES-256, ChaCha20):** Usa uma única chave idêntica para cifrar e decifrar. Excelente para confidencialidade de grandes volumes (BitLocker, banco de dados, túneis VPN). **Atenção de prova:** cifras simétricas NÃO oferecem não-repúdio quando a chave é compartilhada.
- **Criptografia Assimétrica (RSA, ECC, Ed25519):** Usa par de chaves matemáticas: a Chave Pública é distribuída livremente; a Chave Privada é mantida em segredo absoluto pelo titular. Assinar o hash com a chave privada garante **Não-repúdio e Autenticidade**. Cifrar com a chave pública do destinatário garante **Confidencialidade**.
- **Hashing (SHA-256, SHA-3) vs. HMAC:** Hash puro é função matemática unidirecional sem chave, garantindo apenas integridade (qualquer um pode recalculá-lo de um dado adulterado). O HMAC combina hash com chave simétrica secreta, provendo integridade e autenticação mútua entre sistemas conhecidos.
- **TSA (Time Stamping Authority - RFC 3161) e LTV:** Entidade confiável que assina o hash com data/hora auditada, provando o momento exato em que o documento existiu e garantindo validação de longo prazo (LTV) mesmo após a expiração de certificados.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Hash puro NÃO fornece não-repúdio.
- AES com chave compartilhada destrói o não-repúdio.
- Políticas em papel e termos de adesão são controles puramente administrativos; não bloqueiam ataques em tempo de execução.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Sistema-isca que finge ser vulnerável pra atrair e estudar atacantes:

- A)** Honeypot
- B)** DMZ
- C)** Bastion host
- D)** Jump box

2. No modelo Zero Trust, qual é o princípio fundamental?

- A)** Confiar sempre em usuários internos
- B)** Confiar mas verificar
- C)** Nunca confiar, sempre verificar
- D)** Confiar apenas em VPNs

3. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Honeypot = alvo falso: parece real, é monitorado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Honeypot = alvo falso: parece real, é monitorado...

4. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Honeyfile: documento-isca com beacon — dispara alerta ao abrir'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Honeyfile: documento-isca com beacon — dispara alerta ao abrir...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'appears vulnerable but is monitored' = honeypot'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'appears vulnerable but is monitored' = honeypot...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'redirects malicious domain traffic' = sinkhole'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'redirects malicious domain traffic' = sinkhole...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'empresa coloca servidor falsamente vulnerável pra detectar e estudar intrusão' → honeypot.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário típico: 'empresa coloca servidor falsamente vulnerável pra detectar...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Honeypot = alvo falso: parece real, é monitorado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Honeypot = alvo falso: parece real, é monitorado...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Deception & Disruption): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.2), um analista avalia o seguinte requisito técnico: 'Honeyfile: documento-isca com beacon — dispara alerta ao abrir'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Honeyfile: documento-isca com beacon — dispara alerta ao abrir...

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) A — Honeypot.

✓ **Por que está certa:** Honeypot é armadilha: parece alvo real, serve pra detectar/estudar o atacante. Honeynet = rede de honeypots.

✗ **Por que as outras estão erradas:**

- *DMZ:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Bastion host:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Jump box:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) C — Nunca confiar, sempre verificar.

✓ **Por que está certa:** Zero Trust opera no princípio de 'nunca confiar, sempre verificar' ou 'never trust, always verify', eliminando confiança implícita baseada em localização de rede.

✗ **Por que as outras estão erradas:**

- *Confiar sempre em usuários internos:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Confiar mas verificar:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Confiar apenas em VPNs:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) D — Implementar a solução correspondente: Honeypot = alvo falso: parece real, é monitorado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): Honeypot = alvo falso: parece real, é monitorado.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: Honeyfile: documento-isca com beacon — dispara alerta ao abrir....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): Honeyfile: documento-isca com beacon — dispara alerta ao abrir.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para

detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): DNS sinkhole = envia C2 pra IP nulo e LOGA quem tentou.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: 'appears vulnerable but is monitored' = honeypot....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): 'appears vulnerable but is monitored' = honeypot.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: 'redirects malicious domain traffic' = sinkhole....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): 'redirects malicious domain traffic' = sinkhole.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são

controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Cenário típico: 'empresa coloca servidor falsamente vulnerável pra detectar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): Cenário típico: 'empresa coloca servidor falsamente vulnerável pra detectar e estudar intrusão' → honeypot..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: Honeypot = alvo falso: parece real, é monitorado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): Honeypot = alvo falso: parece real, é monitorado.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: Honeyfile: documento-isca com beacon — dispara alerta ao abrir....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.2 (Deception & Disruption): Honeyfile: documento-isca com beacon — dispara alerta ao abrir.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.